网络空间安全导论

数据加密

授课教师：曲海鹏 （quhaipeng@ouc.edu.cn）

PPT版权：徐恪（清华计算机系）、李琦（清华网研院）

1

填空题 5分

请对机制和实例进行匹配（单选）：

1.沙箱 [填空1]

2.入侵容忍 [填空2]

3.可信计算 [填空3]

4.移动目标防御 [填空4]

5.零信任网络 [填空5]

A 在网络边界进行检测的杀毒软件
B 来自"安全"IP地址的访问不一定安全
C 运行在机房的服务器上的操作系统
D FireFox浏览器中的代码运行环境
E 芯片可以对操作系统进行安全验证
F 用公钥密码替代对称密码方案
G 可以自恢复的服务器程序
H 程序在内存中变换地址进行加载

2

密码学简史 → 对称密码 → 公钥密码 → 哈希函数与数字签名 → 密码分析

3

数据安全问题频发



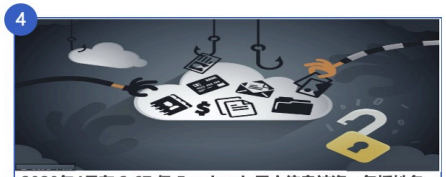
2020年6月，科技巨头甲骨文公司的数据管理平台BlueKai因数据无密码保护导致数十亿人的数据记录泄露



2019年7月，中国智能家居公司欧瑞博（Orvibo）的产品数据库无密码保护导致超过 20 亿条日志泄露



2019年1月，LinkedIn服务器曾遭黑客窃听，1.59亿的用户信息被窃取



2020年4月有 2.67 亿 Facebook 用户信息被盗，包括姓名、邮箱地址、电话、社会身份、性别等

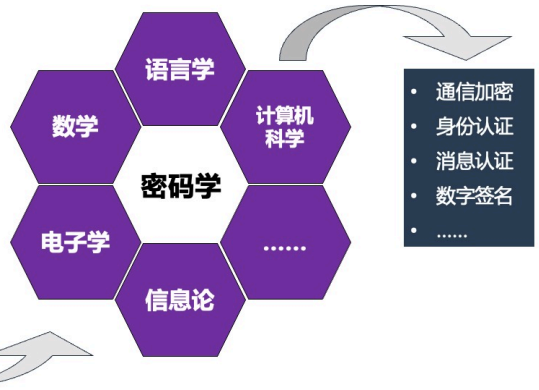
4

雨课堂 Rain Classroom

使用密码保护数据



- 研究密码活动本质和规律
- 指导密码实践
- 探索密码编码和分析的一般规律



- 通信加密
- 身份认证
- 消息认证
- 数字签名
- ……

主要内容

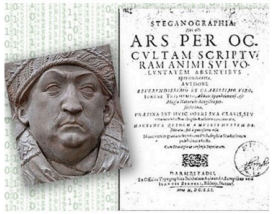
数据加密	要点概括	实例	应用场景
密码学简史	• 古典密码 • 近代密码 • 现代密码	纵行换位密码	/
对称密码	• 分组密码 • 流密码	DES算法	数据安全性
公钥密码	• 密钥分发问题 • 加密原理 • 实际应用	RSA算法	
散列函数	• 性质 • 消息认证码	SHA-256算法	数据完整性
数字签名	• 原理 • 分类	RSA数字签名	身份认证
密码分析技术	• 唯密文攻击 • 已知明文攻击 • 选择明文攻击 • 选择密文攻击	/	对密码算法的设计具有理论指导意义

第1节 密码学简史

- 古典密码
- 近代密码
- 现代密码

隐写术与密码学

- **隐写术是一门关于信息隐藏的技巧与科学**
- **隐写术的英文叫做Steganography，来源于Histaiaeus的一本讲述密码学与隐写术的著作《Steganographia》，该书书名源于希腊语，意为“隐秘书写”**



- **与密码学的区别?**

雨课堂 Rain Classroom

密码学



Ron Rivest

- **密码学（cryptography）**
- **源于希腊语kryptós“隐藏的”，和gráphein“书写”**
- **研究如何隐密地传递信息的学科**
- **著名的密码学者Ron Rivest（RSA作者，图灵奖获得者）：**

“密码学是关于如何在敌人存在的环境中通讯”

9

密码学的基本概念

- **密码编码：**通过信息编码使信息保密
- **密码分析：**用分析方法解密信息
- 基本术语
  - 明文(plain text)，密文(cipher text)
  - 加密(encrypt，encryption)，解密(decrypt，decryption)
  - 密码算法(Algorithm)，密码(Cipher):用来加密和解密的数学函数

    c=E(m)， m=D(c)，D(E(m))= m
  - 密钥(Key): 密码算法中的一个变量（陷门，trapdoor)

    $c=E_{Ke}(m)$，$m=D_{Kd}(c)$，$D_{Kd}(E_{Ke}(m))= m$

密码算法-用于消息认证

MAC（Witness）

Hash

数字签名

密码算法-用于数字签名

10

密码编码

- 把明文转换成密文的两种操作
  - **代替：** each element in the plaintext is mapped into another element
  - **换位：** elements in the plaintext are rearranged
- 密钥的数量
  - Symmetric, secret key, conventional encryption
  - Asymmetric, two keys, public key encryption
- 对明文加密的方式
  - Block cipher
  - Stream cipher

11

密码技术的主要用途

- 数据保密—数据加密/解密
  - 数据加密(存储和传输)
- 认证技术
  - 实体身份认证
  - 数据源发认证
- 信息完整性保护
  - 传输过程中没有被插入、篡改、重发
- 数字签名和抗抵赖
  - 源发抗抵赖
  - 交付抗抵赖







12

雨课堂 Rain Classroom

密码学简史



古典密码



近代密码



现代密码

1949年以前

这一时期的密码学更像是一门艺术，其核心的密码编码方法归根结底主要有两种，即置换和代换

1949年~1975年

香农发表了“保密系统的通信理论”为密码系统建立了理论基础，是密码发展史上的第一次飞跃，密码学迈入近代密码时期

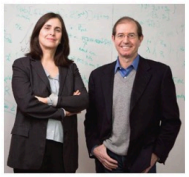
1975年~至今

密码专家迪菲和赫尔曼发表文章“密码学的新方向”提出的公钥密码建立在数学问题难解性问题之上，是密码学的一次真正的革命

13



R. L. Rivest, A. Shamir, and L. Adleman. 1978. A method for obtaining digital signatures and public-key cryptosystems. Commun. ACM 21, 2 (Feb. 1978), 120–126. https://doi.org/10.1145/359340.359342



[1] Shafi Goldwasser, Silvio Micali: Probabilistic Encryption. J. Comput. Syst. Sci. 28(2): 270-299 (1984)
[2] Shafi Goldwasser, Silvio Micali, Ronald L. Rivest: A Digital Signature Scheme Secure Against Adaptive Chosen-Message Attacks. SIAM J. Comput. 17(2): 281-308 (1988)
[3] Shafi Goldwasser, Silvio Micali, Charles Rackoff: The Knowledge Complexity of Interactive Proof-Systems (Extended Abstract). STOC 1985: 291-304

14

古典密码

- **古典密码**
  - 代替密码 (Substitution Cipher)
  - 换位密码 (Transposition Cipher)
  - 代替密码与换位密码的组合
  - 密码体制的安全性在于保持**算法**本身的保密性
- **缺陷**
  - 受限算法的缺陷
    - 不适合大规模使用
    - 不适合较大的或者人员变动较大的组织
    - 用户无法了解算法的安全性

15

Caesar密码

凯撒(Caesar)密码是公元前一世纪在高卢战争时被使用的，它是将英文字母向前移动k位

明文	A	B	C	D	E	F	G	H	I	J	K	L	M
密文	F	G	H	I	J	K	L	M	N	O	P	Q	R
明文	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
密文	S	T	U	V	W	X	Y	Z	A	B	C	D	E

凯撒密码明密文对应表

明文：i went to school this morning

密文：n vjsz zu yhmuuq zmny ruxsnsl

CAESAR 密码： c=(m+ 5) MOD 26

16

雨课堂 Rain Classroom

猪圈密码

猪圈密码是一种以格子为基础的简单替代式密码，格子如下：



密文为：



明文为：HOW ARE YOU

纵行换位密码

- 换位密码就是一种早期的加密方法，明文的字母保持相同，但顺序被打乱了
- 广泛应用于美国南北战争

输入方向 →

C	A	N	Y
O	U	U	N
D	E	R	S
T	A	N	D

输出方向 ↓

明文：Can you understand

密文：Codtaueanurnynsd

戚继光 反切码

反切码源自反切拼音注音方法，是用两个字为另一个字注音，取上字的声母和下字的韵母，“切”出另外一个字的读音



诗篇1声母	1	2	3	4	5		6	7	8	9	10		11	12	13	14	15					
	l	b	q	q	d		b	t	zh	r	sh		y	m	y	ch	x		d	zh	y	j	zh
	柳	边	求	气	低	，	波	他	争	日	时	，	莺	蒙	语	出	喜	，	打	掌	与	君	知
诗篇2韵母	1	2	3		4	5	6		7	8	9	10	11	12	13		14	15	16	17	18	19	
	un	ua	iang		iu	an	ai		ia	in	uan	e	u	in	ei		u	eng	uang	ui	ao	in	
	春	花	香	，	秋	山	开	，	嘉	宾	欢	歌	须	金	杯	，	孤	灯	光	辉	烧	银	
	20		21	22	23		24	25	26		27	28	29	30	31		32	33	34	35	36		
	ang		i	ong	iao		uo	i	iao		i	eng	ui	u	ian		i	ei	ai	e	ou		
	缸	。	之	东	郊	，	过	西	桥	，	鸡	声	催	初	天	，	奇	梅	歪	遮	沟	。	

戚继光 反切码

反切码源自反切拼音注音方法，是用两个字为另一个字注音，取上字的声母和下字的韵母，“切”出另外一个字的读音



举例：

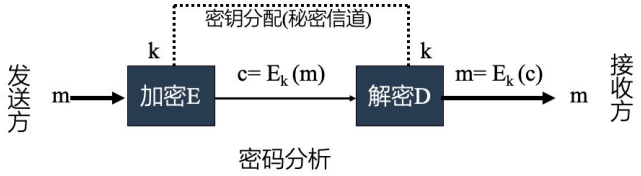
密文：5-25-2

5		25			
d	+	i	→	di	→ 明文：敌
低		西			
诗篇1声母		诗篇2韵母		声调2声	

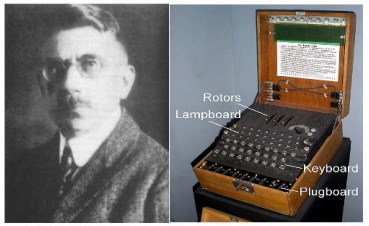
雨课堂 Rain Classroom

近代密码

- 将**算法**和**密钥**分开
- 密码算法可以公开，密钥保密
- 密码系统的安全性在于保持密钥的保密性

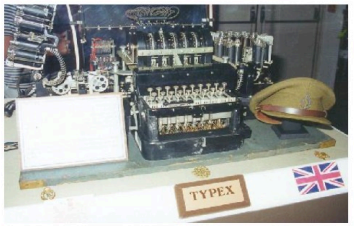


ENIGMA机



Arthur Scherbius与转轮密码机ENIGMA

- 转轮密码机ENIGMA，由Arthur Scherbius于1919年发明，1926年装备德军

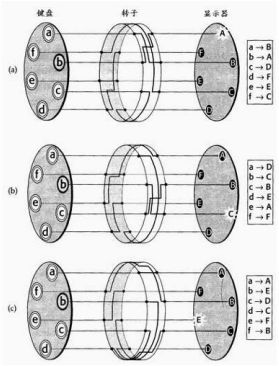


TYPEX打字密码机

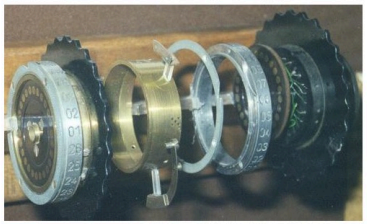
- 英国的TYPEX打字密码机，是德国3轮ENIGMA的改进型密码机，它在英国通信中广泛使用

ENIGMA机工作原理

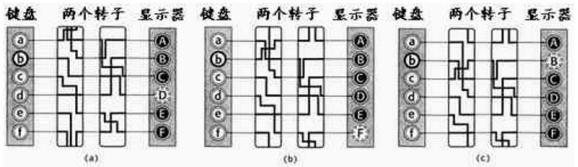
连续键入三个**b**：

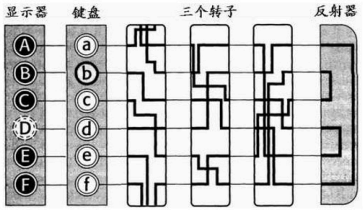


实物图：

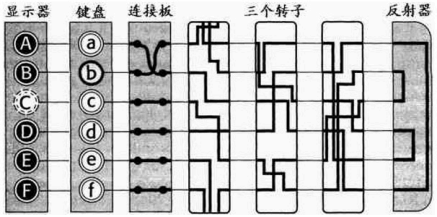


ENIGMA机工作原理





ENIGMA机工作原理



- 转子的初始设置，转子之间的相互位置，以及连接板连线的状况组成了所有可能的密匙
- 三个转子不同的方向组成了**26*25*26=16900**种不同可能性
- 三个转子间不同的相对位置为**6**种可能性
- 连接板上两两交换**6**对字母的可能性为 **C(26,6)*C(20,6)*6!/64 = 100391791500**
- 共有**16900*6*100391791500**，约为一亿亿种可能性

25

ENIGMA工作过程

- **根据密码本取得当日密钥**
- **首先发送一个新的密钥**
  - 随机地选择三个字母，比如说PGH
  - 把PGH在键盘上连打两遍，加密为比如说KIVBJE（注意两次PGH被加密为不同的形式）
  - 把KIVBJE放在在电文的最前面
- **重新调整三个转子的初始方向到PGH**
- **正式对明文加密**

26

ENIGMA破解


Marian Adam Rejewski


Jerzy Witold Różycki


Henryk Zygalski

- 20世纪30年代，马里安·雷耶夫斯基、杰尔兹·罗佐基与亨里克·佐加尔斯基等人一同进行了对德国Enigma密码的破译工作，并称为密码研究领域的“波兰三杰”。
- 2000年7月17日，波兰政府向雷耶夫斯基、罗佐基和佐加尔斯基追授波兰最高勋章

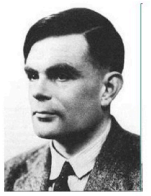
27

ENIGMA破解

- 阿兰·麦席森·图灵

  Alan Mathison Turing

  1912.6.23—1954.6.7
- 英国数学家、逻辑学家，他被视为计算机之父
- 1931年图灵进入剑桥大学国王学院，毕业后到美国普林斯顿大学攻读博士学位，二战爆发后回到剑桥，后曾协助军方破解德国的著名密码系统Enigma，帮助盟军取得了二战的胜利





28

ENIGMA破解-Turing Bombe



现代密码

- 对称密钥密码系统的缺陷
  - 密钥必须经过安全的信道分配
  - 无法用于数字签名
  - 密钥管理复杂 $O(n^2)$

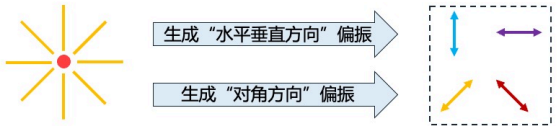


- 1976 年，Diffie和Hellman发表了《*New Direction in Cryptography*》提出了“公钥密码”的概念，获得2015年图灵奖
- 使用**两个**密钥，对于密钥分配、数字签名、认证等有深远影响
- 基于**数学函数**而不是代替和换位，密码学历史上唯一的一次真正的革命，实现了密码学发展史上的**第二次飞跃**

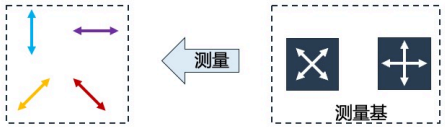
30

量子密码

- 量子密码体系采用量子态作为信息载体，经由量子通道在合法的用户之间传送密钥，其安全性由量子力学原理所保证
- 光的偏振：



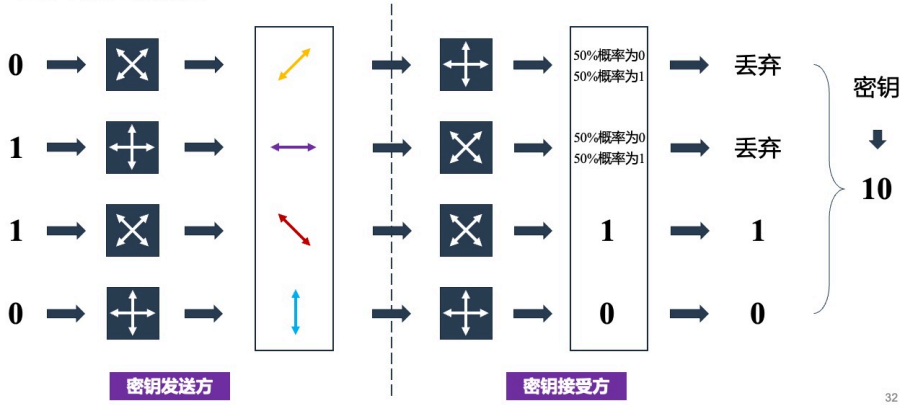
- 偏振方向测量：



31

量子密码

量子密钥生成方法：



32

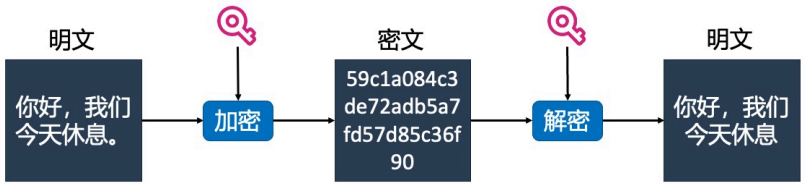
第2节 对称密码

- 分组密码
- DES算法
- 流密码

33

对称密码

- 加密和解密使用**相同的密钥**：$K_E=K_D$
- 密钥必须使用**秘密的信道**分配
- 常用对称密钥密码算法
  - DES (Data Encryption Standard)及其各种变体
  - AES (Advanced Encryption Standard)



34

对称密码基本设计原则

- 对称加密算法对称密码算法的两条基本设计原则：
  - （1）扩散（Diffusion）

    重新排列消息中的每一个比特，使明文中的冗余度能够扩散到整个密文，将每一个比特明文的影响尽可能作用到较多的输出密文位中
  - （2）扰乱（Confusion）

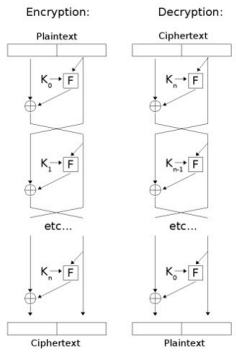
    密文和密钥之间的统计特性关系尽可能复杂化。如果密钥的一位发生变化，密文的绝大多数位也发生变化
- 多次迭代是基本设计方法



克劳德·艾尔伍德·香农
信息论创始人

35

对称密码基本设计原则



Feistel Cipher

- **霍斯特·菲斯特尔（Horst Feistel）**
  分组密码之父
- 1973年他在 Scientific American 杂志上发表了Cryptography and Computer Privacy一文，提出了Feistel网络
- 多轮迭代结构
- 加密解密对称

36

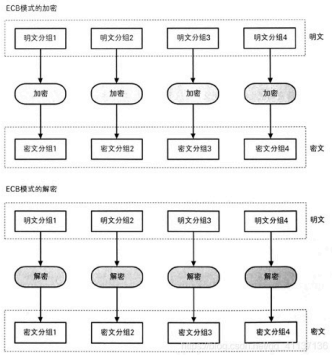
雨课堂 Rain Classroom

分组密码

- 分组密码(block cipher)是每次只能处理特定长度的一块数据的一类密码算法
- 对不同分组主要有5种迭代模式
  - ECB模式：Electronic CodeBook mode（电子密码模式）
  - CBC模式：Cipher Block Chaining mode（密码分组链接模式）
  - CFB模式：Cipher FeedBack mode（密文反馈模式）
  - OFB模式：Output FeedBack mode（输出反馈模式）
  - CTR模式：CounTeR mode（计数器模式）

ECB模式

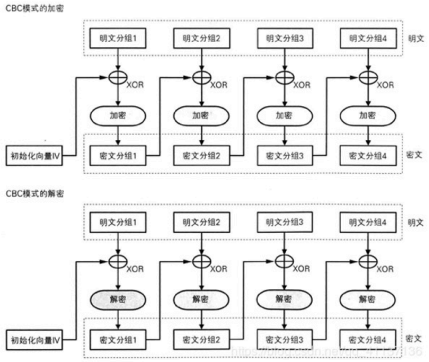
ECB模式的全称Electronic CodeBook 模式(电子密码模式)。在ECB中，明文分组加密后的结果直接作为密文分组



优点:
(1)每个分组的处理相互独立，可以并行操作
(2)一个密文块传输错误不会影响后续密文解密， 是分组密码的标准工作模式
缺点:
(1)因分组相互独立，信息块可被替换、重排、删除、重放，所以对明文的主动攻击是可能的
(2)无法纠正传输中的同步错误

CBC模式

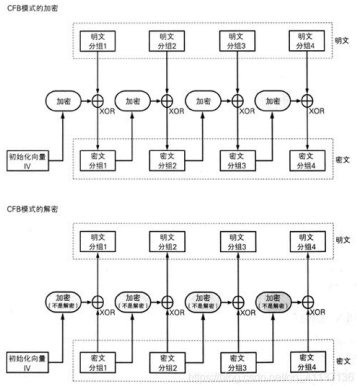
CBC 模式的全称Cipher Block Chaining模式(密码分组链接模式)



优点:
(1)能够隐藏明文的数据模式，相同的明文可对应不同的密文
(2)在一定程度上抵抗主动攻击
(3)误差有限传递
缺点:
加密不支持并行计算

CFB模式

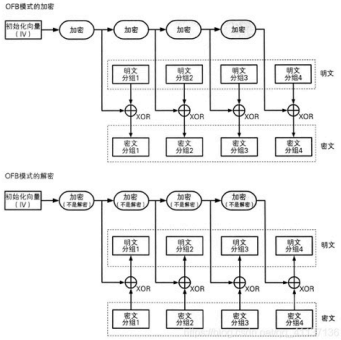
CFB模式全称Cipher FeedBack 模式(密文反馈模式)



优点:
（1）能够隐藏明文的数据模式
（2）在一定程度上抵抗主动攻击
（3）解密支持并行计算
缺点:
（1）加密不支持并行计算
（2）一个密文块传输错误会影响后续密文解密

OFB模式

OFB全称 Output FeedBack 模式 (输出反馈模式) 。在OFB中，密码算法的输出会反馈至密码算法的输入中，即上一轮加密算法的输出会作为下一轮加密算法的输入

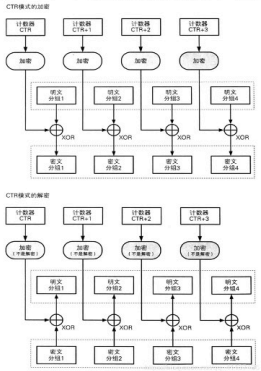


优点:
没有错误传播，一个密文单元的损坏只影响本单元的解密
缺点:
(1)对密文的主动攻击难以检测
(2)加密时不支持并行计算

41

CTR模式

CTR的全称 Counter模式(计数器模式)。CTR 是一种通过将逐次累加的计数器进行加密来生成密钥流的分组密码



优点:
(1) 可以随机地对任意一个密文分组进行解密，对该密文分组的处理与其他密文处理无关
(2) 能并行加解密处理，多个分组同时进行，效率高
缺点:
对密文的主动攻击难以检测

42

DES算法原理

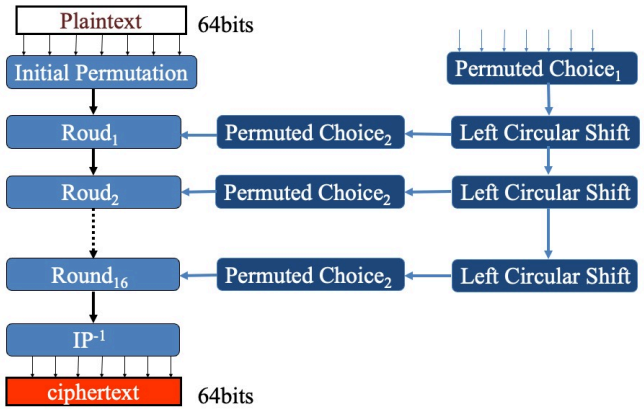
- IBM 公司，70年代初提出
- DES是一种对称密钥算法，密钥长度为56bits (加上奇偶校验，通常写成64bits)
- 是一种分组加密算法，64 bits为一个分组
- 使用标准的**算术**和**逻辑**运算
- 首先把明文分成以64 bit为单位的块m，对于每个m，执行如下操作:

  $DES(m)=IP^{-1} \cdot T16 \cdot T15 \cdot \ldots . T2 \cdot T1 \cdot IP(m)$

  - 初始置换， IP
  - 16轮迭代，Ti， i=1,2,…16
  - 末置换，IP^{-1}

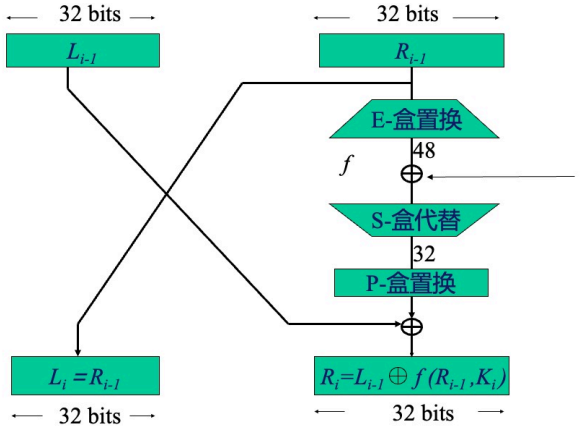
43

对称密码基本设计原则



44

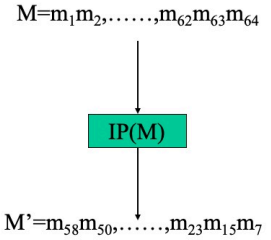
一轮迭代



关键组件: 初始置换

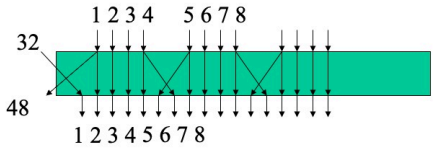
- 初始置换(*IP*)

58	50	42	34	26	18	10	2
60	52	44	36	28	20	12	4
62	54	46	38	30	22	14	6
64	56	48	40	32	24	16	8
57	49	41	33	25	17	9	1
59	51	43	35	27	19	11	3
61	53	45	37	29	21	13	5
63	55	47	39	31	23	15	7



关键组件: 扩展置换（E-盒置换）

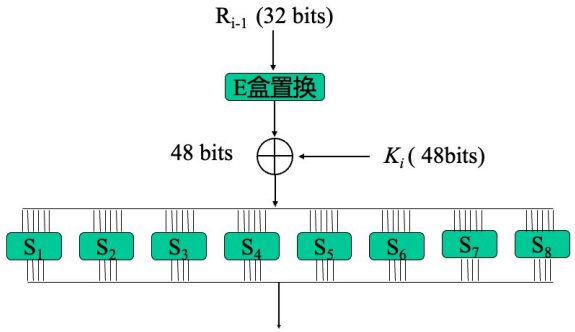
- 将R_i从32位扩展到48位，便于和密钥操作
- **目的：**输入的一位影响下一步的两个替换，使得输出对输入的依赖性传播得更快，密文的每一位都依赖于明文的每一位



1	2	3	4	5	6	7	8	9	10	11	12	13	14	……46	47	48
32	1	2	3	4	5	4	5	6	7	8	9	8	9….	31	32	1

关键组件: S-盒代替

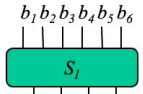
- 将48比特压缩成32比特



雨课堂 Rain Classroom

S-盒代替

- 输入6比特: $b_1b_2b_3b_4b_5b_6$
- 输出4比特: S(b_1b_6，$b_2b_3b_4b_5$)



		0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15
S1	0	14	4	13	1	2	15	11	8	3	10	6	12	5	9	0	7
	1	0	15	7	4	14	2	13	1	10	6	12	11	9	5	3	8
	2	4	1	14	8	13	6	2	11	15	12	9	7	3	10	5	0
	3	15	12	8	2	4	9	1	7	5	11	3	14	10	0	6	13
S2	0	15	1	8	14	6	11	3	4	9	7	2	13	12	0	5	10
	1	.	.	..	..	..	..										
	2																
	3																

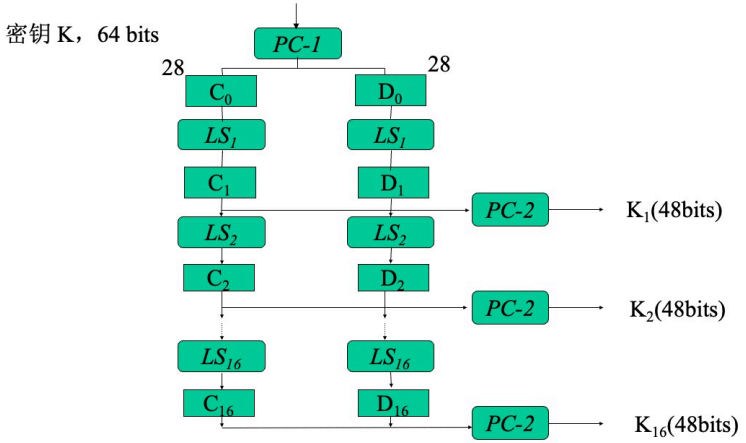
举例： $S_1(100110) = 1000$

关键组件: P盒置换

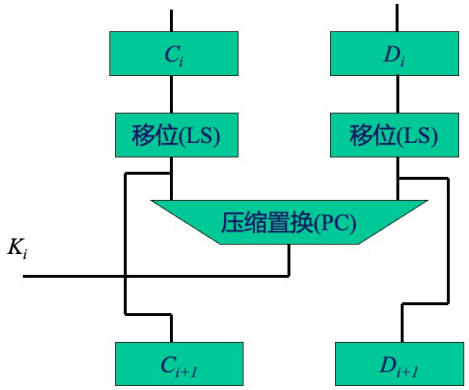
- P盒置换: 将32位进行置换

16	7	20	21	29	12	28	17
1	15	23	26	5	18	31	10
2	8	24	14	32	27	3	9
19	13	30	6	22	11	4	25

子密钥生成



子密钥生成



雨课堂 Rain Classroom

子密钥生成

- 拆分：56 bits 的密钥分成两部分，C_i, D_i，各28bits
- 循环左移：根据迭代的轮数，分别左移一位或两位

1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16
1	1	2	2	2	2	2	2	1	2	2	2	2	2	2	1

- 压缩置换(置换选择)：从56bits中选择48bits

14	17	11	24	1	5	3	28	15	6	21	10
23	19	12	4	26	8	16	7	27	20	13	2
41	52	31	37	47	55	30	40	51	45	33	48
44	49	39	56	34	53	46	42	50	36	29	32

53

子密钥生成

- 末置换

40	8	48	16	56	24	64	32
39	7	47	15	55	23	63	31
38	6	46	14	54	22	62	30
37	5	45	13	53	21	61	29
36	4	44	12	52	20	60	28
35	3	43	11	51	19	59	27
34	2	42	10	50	18	58	26
33	1	41	9	49	17	57	25

- 初始置换

58	50	42	34	26	18	10	2
60	52	44	36	28	20	12	4
62	54	46	38	30	22	14	6
64	56	48	40	32	24	16	8
57	49	41	33	25	17	9	1
59	51	43	35	27	19	11	3
61	53	45	37	29	21	13	5
63	55	47	39	31	23	15	7

$IP^{-1}(IP(M))=M$

54

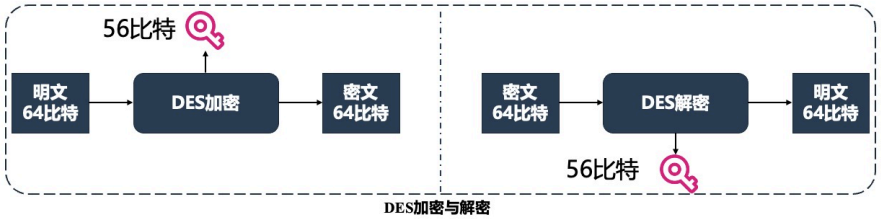
DES解密过程

- DES解密过程与加密过程完全相似，只不过将16次迭代的子密钥顺序倒过来，即

$$m = DES^{-1}(c) = IP^{-1} \bullet T_1 \bullet T_2 \bullet \ldots . T_{15} \bullet T_{16} \bullet IP(c)$$

- 可以证明，

$$DES^{-1}(DES(m)) = m$$

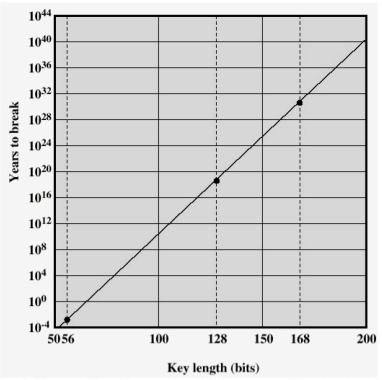


DES加密与解密

55

软硬件实现与破译

- 硬件实现
  - 商业DES芯片或者FPGA实现
  - 目前可支持1.5Gbps以上的加解密速度
- 软件实现
  - 80486, CPU 66MHz，每秒加密43000个DES分组, 336K Bytes/s
  - HP 9000/887, CPU 125 MHz，每秒加密196,000个分组, 1.53M Bytes/s
- 破译速度
  - 56位密钥长度需要20小时即可破译
  - 128位密钥长度需要5.4 x 1018年破译
  - 168位密钥长度需要5.9 x 1030 年破译



Time to break a code (106 decryptions/μs)

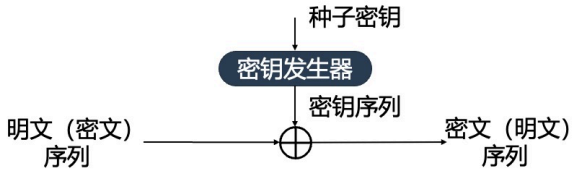
56

DES的一般设计准则

- 随机性
  - 输出与输入间是无规律的
- 雪崩效应
  - 改变输入中的1位，平均导致大约一半的输出位被改变
- 完全性
  - 每个输出位都是所有输入位的复杂函数
- 非线性
  - 加密函数对于任何密钥值都是非线性的
- 相关关系免疫性
  - 输出统计上独立于任何输入位的子集

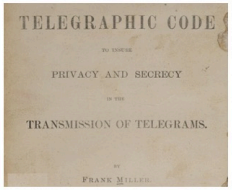
流密码

- 流密码是对数据流进行连续处理的一类密码算法
- 流密码中一般以1比特、8比特或32比特等为单位进行加密或解密
- 流密码是对一串数据流进行连续处理，因此需要保持内部状态



一次性密码本

一次性密码本(One-Time Pad，OTP)在1882年被弗兰克·米勒(Frank Miller)发现，并沿用至今


TELEGRAPHIC CODE
PRIVACY AND SECRECY
TRANSMISSION OF TELEGRAMS.
FRANK MILLER.

- 首先将明文morning这个字符串通过ASCII进行编码并产生一串字符串：

m	o	r	n	i	n	g	
01101101	01101111	01110010	01101110	01101001	01101110	01100111	morning

- 然后，产生一个与明文长度相同的随机比特序列：

01111101	00001111	01101101	01111110	01101011	01111110	01100101	密钥

一次性密码本

1.加密过程

将明文与密钥进行异或操作，得到的结果即为OTP的密文

	01101101	01101111	01110010	01101110	01101001	01101110	01100111	morning
⊕	01111101	00001111	01101101	01111110	01101011	01111110	01100101	密钥
	00010000	01100000	00011111	00010000	00000010	00010000	00000010	密文

2.解密过程

解密是加密的反向运算。解密OPT的过程即是将密文和密钥进行异或运算的过程

	00010000	01100000	00011111	00010000	00000010	00010000	00000010	密文
⊕	01111101	00001111	01101101	01111110	01101011	01111110	01100101	密钥
	01101101	01101111	01110010	01101110	01101001	01101110	01100111	明文
	m	o	r	n	i	n	g	morning

雨课堂 Rain Classroom

一次性密码本

3. 无法被破译

即使能够解密出morning这个字符，我们也无法判断它是否是正确的明文

4. 局限性

(1) 密钥分发问题
(2) 密钥保存问题
(3) 密钥的重用问题
(4) 密钥的同步问题
(5) 密钥的生成问题

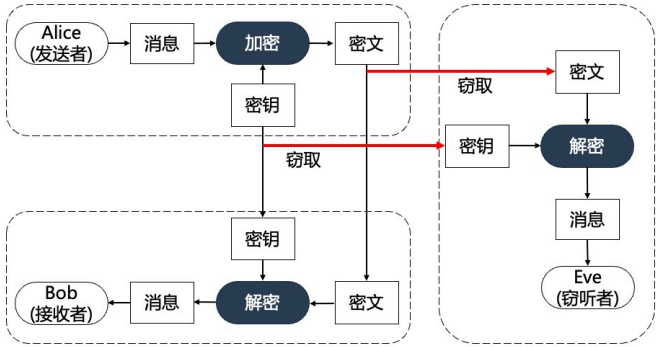
61

第3节 公钥密码

- 密钥分发问题
- 公钥密码
- RSA算法
- 实际应用

62

密钥分发问题



63

解决密钥分发问题

- **通过事先共享密钥来解决**

  在加密通信以前，事先用安全的方式将密钥交给接收方

- **通过密钥分配中心来解决**

  当参与加密通信的人过多，可以使用密钥分配中心(Key Distribution Center, KDC) 。当需要进行加密通信时，密钥分配中心会生成一个通信密钥，每个人只需和KDC事先共享密钥即可

- **通过Diffie-Hellman密钥交换来解决**

  进行加密通信的双方仅需要交换一些信息，该信息即使被窃听也无法对算法进行解密，而通信双方则可以通过该信息各自生成相同的密钥

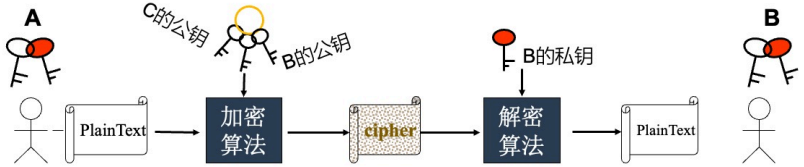
- **通过公钥密码来解决**

  由于加解密使用不同密钥，故无需进行密钥分发

64

公钥密码系统的加密原理

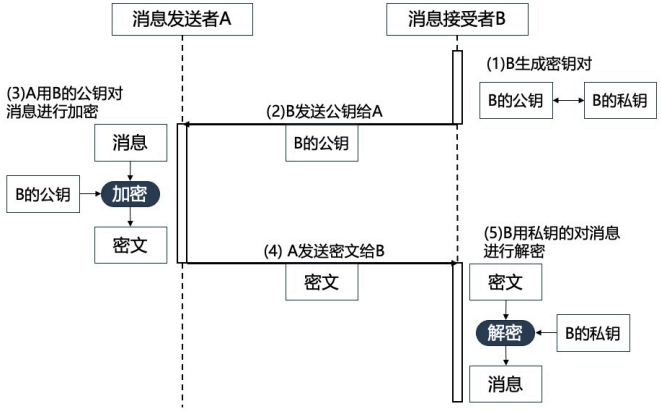
- 每个通信实体有一对密钥(公钥，私钥)
  - 公钥公开，用于加密和验证签名，私钥保密，用作解密和签名
- A向B 发送消息，用B的公钥加密
- B收到密文后，用自己的私钥解密



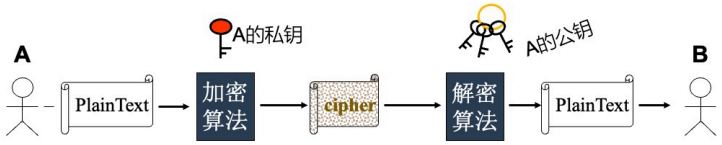
任何人向B发送信息都可以使用同一个密钥(B的公钥)加密

没有其他人可以得到B的私钥，所以只有B可以解密

公钥密码系统的加密原理



公钥密码系统的签名原理



- A向B发送消息，用A的私钥加密(签名)
- B收到密文后，用A的公钥解密(验证)

公钥密码算法的表示

- 对称密钥密码
  - 密钥：会话密钥(Ks)
  - 加密函数：C= E_{Ks}[P]
  - 对密文C，解密函数：D_{Ks}[C]
- 公开密钥
  - (KUa，KRa)
  - 加密/签名：C= E_{KUb}[P]，E_{KRa}[P]
  - 解密/验证：P= D_{KRb}[C]，D_{KUa}[C]

对公开密钥密码算法的要求

- 参与方B容易产生密钥对(KUb, KRb)
- 已知KUb，A的加密操作是容易的

  $C=E_{KUb}(P)$
- 已知KRb，B的解密操作是容易的

  $P=D_{KRb}(C) = D_{KRb}(E_{KUb}(P))$
- 已知KUb，求KRb是计算上不可行的
- 已知KUb和C，欲恢复P是计算上不可行的

69

对公钥密码算法的误解

- 公开密钥算法比对称密钥密码算法更安全
  - 任何一种算法都依赖于密钥长度、破译密码的工作量，从抗分析角度，**没有一方更优越**
- 公开密钥算法使对称密钥成为过时的技术
  - 公开密钥很慢，只能用在密钥管理和数字签名，对称密钥密码算法将**长期存在**
- 使用公开密钥加密，密钥分配非常简单
  - 事实上的密钥分配既不简单，也不有效

70

RSA算法简介

- Ron Rivest, Adi Shamir , Leonard Adleman

  ——获得2002年图灵奖
- RSA的安全性基于大数分解的难度
- RSA在美国申请了专利(已经过期)，在其他国家没有
- RSA已经成了事实上的工业标准，在美国除外
- RSA算法既可以用于公钥密码也可以用于数字签名

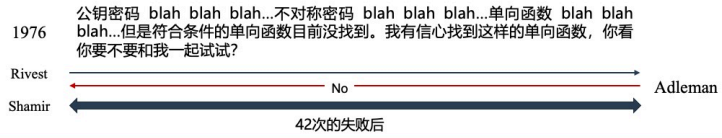


71

RSA算法诞生



- Ron Rivest、Adi Shamir 和 Leonard Adleman 三个人风格迥异，组成了一个技能互补的完美团队
- 1977年，三人在MIT合作发表了一篇完整描述RSA算法的论文，RSA也正是由三人姓氏的首字母组成



作者：RL Rivest - 1978 - 被引用次数：21052 - 相关文章

A method for obtaining digital signatures and public-key cryptosystems, Published by ACM 1978

72

RSA论文的评审意见

A Method for Obtaining Digital Signatures and Public-Key Cryptosystems. According to the (very short) introduction, this paper purports to present a practical implementation of Diffie and Hellman's public-key cryptosystem for applications in the electronic mail realm. If this is indeed the premise, **the paper should be rejected both for a failure to live up to it and for its irrelevance.**

I doubt that a system such as this one will ever be practical. The paper does a poor job of convincing the reader that practicality is attainable.

The introduction is only two paragraphs long, the relevant literature is not presented or cited, and there is virtually no comparison with the relevant work in the area. In summary, it looks as if this paper is a mathematical exercise **with little originality** (the authors claim that most of their ideas come from other papers), **too far from practical applicability**, **running against the established standards**, and **with a declared application area of dubious** feasibility. Not the kind of material our readers like to see in the journal. **Reject**.

73

RSA算法的安全性

- 攻击方法
  - 蛮力攻击：对所有密钥都进行尝试
  - 数学攻击：等效于对两个素数乘积(n)的因子分解
- 大数的因子分解是数论中的一个难题

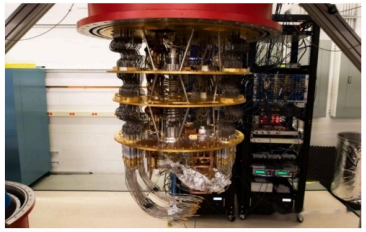
因子分解的进展

十进制数字位数	近似比特数	得到的数据	MIPS年
100	332	1991	7
110	365	1992	75
120	398	1993	830
129	428	1994	5000
130	431	1996	500

74

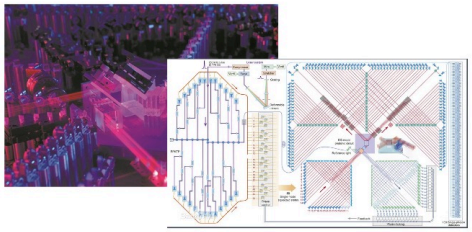
RSA算法面临挑战：量子计算

- Sycamore(悬铃木)



- 2019年9月谷歌研制出量子计算机Sycamore
- 仅用 53 个量子位就在短短几分钟时间内完成了一项高难度计算任务
- 当时世界最先进的超级计算机 Summit 耗时 1 万年也不可能完成

- 九章



- 2020年12月4日，中科大潘建伟等人成功构建76个光子的量子计算原型机“九章”
- 求解一项高难度计算任务仅需200s
- 计算相同问题目前世界最快超级计算机“富岳”需6亿年

75

RSA算法的性能

- 速度
  - 软件实现比DES慢100倍
  - 硬件实现比DES慢1000倍

8位公开密钥的RSA的加密速度	512位	768位	1024位
加密（秒）	0.03	0.05	0.08
解密（秒）	0.16	0.48	0.93
签名（秒）	0.16	0.52	0.97
验证（秒）	0.02	0.07	0.08

76

雨课堂 Rain Classroom

RSA算法操作过程

- 密钥产生
  1. 取两个大素数 p, q , **保密** — *p=7,q=17*
  2. 计算$n=pq$，公开n — *n=119*
  3. 计算欧拉函数$\varphi(n) = (p-1)(q-1)$ — *φ(n)=96*
  4. 任意取一个与$\varphi(n)$互素的小整数e, 即 — *取e=5*

     $gcd\ (e,\varphi(n)\ )=1;\ \ 1<e<\varphi(n)$
  5. 寻找d, $d<\varphi(n)$, 使得 $de \equiv 1\ mod\ \varphi(n)$, $de = k\ \varphi(n) + 1$ — *5d=k×96+1 取 k=4, 得到 d=77*

  公开$(e, n)=(5, 119)$

  将d 保密，丢弃 p, q

77

RSA算法加密/解密

- 公开密钥: KU={e, n} — {5, 119}
- 秘密密钥: KR={d, n} — {77, 119}
- 加密过程
  - 把待加密的内容分成k比特的分组
    $k \le \log_2 n$，并写成数字，设为M，则
    $C = M^e \bmod n$ — $c=m^5 \bmod 119$
- 解密过程

  $M = C^d \bmod n$ — $m=c^{77} \bmod 119$

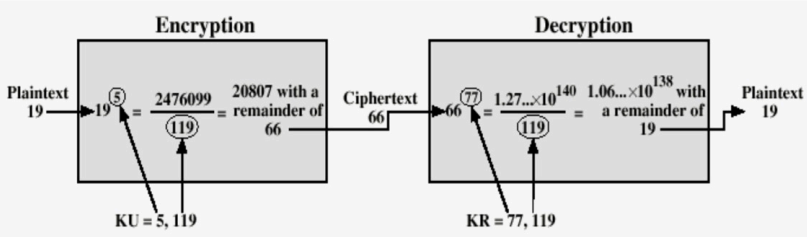
Remember:

$ed = k\varphi(n) + 1$

$M^{k\varphi(n)+1} \equiv M \bmod n$

78

RSA算法举例



79

公钥密码系统的应用

- 三种用途：
  - 加密/解密
  - 数字签名：发送方用自己的私钥签署报文，接收方用对方的公钥验证对方的签名
  - 密钥交换：双方协商会话密钥

算法	加密/解密	数字签名	密钥交换
RSA	**Y**	**Y**	**Y**
Diffie-Hellman	**N**	**N**	**Y**
DSA	**N**	**Y**	**N**

80

雨课堂 Rain Classroom

第4节 哈希函数与签名

- 散列函数
- 消息认证码
- 数字签名

81

数字签名与哈希函数

- 将数据比作一个幼儿
- 数据加密即使给幼儿“穿衣服”
- 数字签名在衣服上留下“印记”
- 哈希值是孩子的“健康证明”







82

哈希（Hash）函数

- 又叫单向哈希(散列)函数、密码学哈希(散列)函数等
- 把任意长度的消息压缩为固定长度的二进制串：散列值(hash value)：

$$h = H(m)$$

- 是进行消息认证的基本方法，主要用于消息完整性检测和数字签名



83

哈希函数

- 纵向的奇偶校验码

	比特1	比特2	……	比特n
分组1	b_{11}	b_{21}	…	b_{n1}
分组2	b_{12}	b_{22}	…	b_{n2}
	.	.	…	.
分组m	b_{1m}	b_{2m}		b_{nm}
散列码	C_1	C_2		C_n

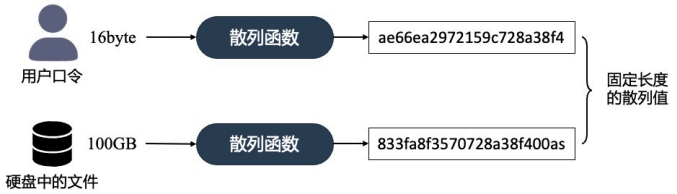
$C_i = b_{i1} \oplus b_{i2} \cdots \oplus b_{im}$

84

雨课堂 Rain Classroom

哈希函数的性质

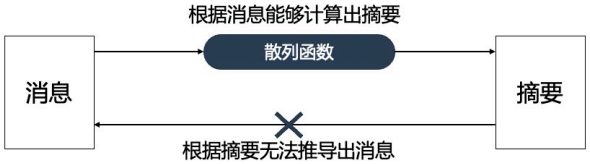
(1) 根据任意长度的消息计算出固定长度的散列值



(2) 能够快速计算出散列值

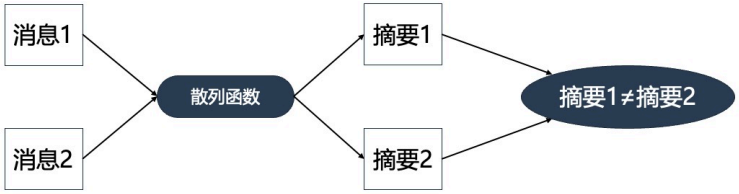
哈希函数的性质

(3) 单向性



哈希函数的性质

(4) 消息不同散列值也不同



安全性：HASH 碰撞

- 2005年5月国际密码学会议（Eurocrypto’ 2005） 王小云院士发表论文”How to break MD5 and other hash functions”
- 成功破译**MD5、HAVAL-128、MD4**和**RIPEMD**算法
- 该次会议的总结报告写道：“我们该怎么办？MD5被重创了，它即将从应用中淘汰。SHA-1仍然活着，但也看到了它的末日，现在就得开始更换SHA-1了”



王小云院士

How to Break MD5 and Other Hash Functions

Xiaoyun Wang and Hongbo Yu

SHA1碰撞的理论计算上界

- 2005年2月7日，美国国家标准技术研究院NIST对外宣称：SHA-1还没有被攻破，并且也没有足够的理由怀疑它会很快被攻破
- **2005年8月，王小云教授再度令世界密码学界大跌眼镜——SHA-1也被她攻破了！王教授提出了复杂度为2^69的理论攻击**
- Finding collisions in the full SHA-1. Crypto’ 2005

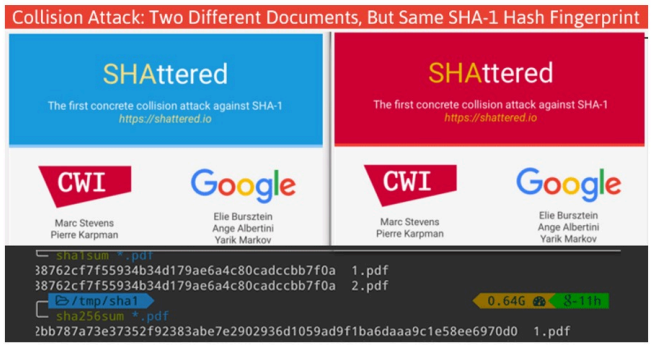
Finding Collisions in the Full SHA-1

Xiaoyun Wang[1,⋆], Yiqun Lisa Yin[2], and Hongbo Yu[3]

89

安全性：HASH碰撞

2017年2月23号，Google在其安全博客上公布了其找到了世界首例的SHA1碰撞，标志着SHA1不再安全了



90

哈希算法实例

算法名称	输出长度（Bits）	简述
MD4	128	由Rivest于1990年针对32位操作系统所设计，于1996年被破解，但对后来的MD5、SHA系列和RIPEMD算法产生了深远影响
MD5	128	由Rivest于1991年对MD4算法改进而来，在MD4的基础上增加了"安全带"（safety-belts）的概念。2004年其强抗碰撞性被攻破
SHA-1	160	由NIST（美国国家标准技术研究所）在MD5的基础上改进而来，其强抗碰撞性于2005年被山东大学王小云教授团队攻破
SHA-256	256	SHA-2系列的一种版本，由NIST设计，用到了8个哈希初值以及32个哈希常量。该算法被用于生成比特币地址
SHA-512	512	SHA-2系列的一种版本，由NIST设计，用到了8个哈希初值以及64个哈希常量
SHA-3	任意长度	在2005年SHA-1的强抗碰撞性被攻破的背景下，NIST开始设计下一代哈希函数SHA-3。2012年10月，NIST选择Keccak算法作为SHA-3的标准算法

91

散列函数的应用: 比特币

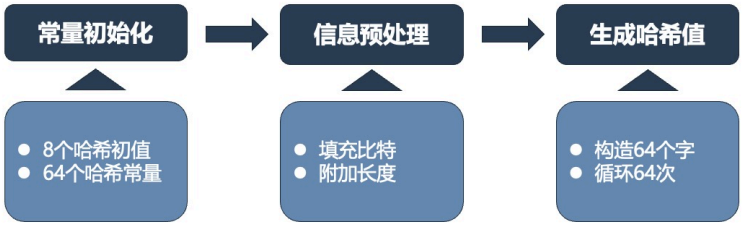


- 比特币是一种P2P形式的虚拟的加密数字货币，使用了SHA256、RIPEMD160
- SHA256
  - 输出：256位的哈希值
  - 用途：区块的头部信息、交易数据、工作量证明、比特币地址等
- RIPEMD160
  - 输出：160位的哈希值
  - 用途：比特币地址生成，可以让地址更短

92

SHA256算法

SHA256是SHA-2标准下细分出的一种散列函数。算法的实现主要分为三个步骤：实现可以分为三个部分：常量初始化，信息预处理，生成哈希值



SHA256算法

1. 常量初始化

SHA256算法中用到了8个哈希初值以及64个哈希常量。其中8个哈希初值，分别是最开始的连续8个素数（即2,3,5,7,11,13,17,19）的平方根的二进制表示的小数部分的前32位

h0 := 0x6a09e667	h1 := 0xbb67ae85	h2 := 0x3c6ef372	h3 := 0xa54ff53a
h4 := 0x510e527f	h5 := 0x9b05688c	h6 := 0x1f83d9ab	h7 := 0x5be0cd19

还要初始化64个值，分别是最开始的连续64个素数（从2到311）的立方根的二进制表示的小数部分的前32位

428a2f98	71374491	b5c0fbcf	e9b5dba5	3956c25b	59f111f1	923f82a4	ab1c5ed5
d807aa98	12835b01	243185be	550c7dc3	72be5d74	80deb1fe	9bdc06a7	c19bf174
e49b69c1	efbe4786	0fc19dc6	240ca1cc	2de92c6f	4a7484aa	5cb0a9dc	76f988da
983e5152	a831c66d	b00327c8	bf597fc7	c6e00bf3	d5a79147	06ca6351	14292967
27b70a85	2e1b2138	4d2c6dfc	53380d13	650a7354	766a0abb	81c2c92e	92722c85
a2bfe8a1	a81a664b	c24b8b70	c76c51a3	d192e819	d6990624	f40e3585	106aa070
19a4c116	1e376c08	2748774c	34b0bcb5	391c0cb3	4ed8aa4a	5b9cca4f	682e6ff3
748f82ee	78a5636f	84c87814	8cc70208	90befffa	a4506ceb	bef9a3f7	c67178f2

SHA256算法

2. 信息预处理

信息的预处理分为两个步骤：附加**填充比特**和**附加长度**

①附加填充比特

填充过程：第一个填充的比特为1，其后的填充的比特都为0，直到长度满足对512取模后余数是448

例：以信息“abc”为例介绍补位的过程

信息	a	b	c
ASCII码（二进制）	01100001	01100010	01100011
补位（第一位补“1”）	01100001 01100010 01100011 1		
补位（其后位补“0”）	01100001 01100010 01100011 10000000 00000000 … 00000000(423个0)		
结果（十六进制）	61626380 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000		

SHA256算法

②附加长度

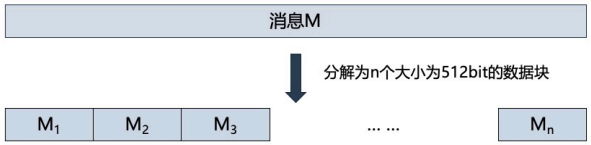
- 将原始数据的长度信息补到已经进行了填充操作的消息后
- 消息“abc”，3个字符，占用24个bit，附加长度后的消息如下

长度附加前	61626380 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000
长度附加后	61626380 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000000 00000018

SHA256算法

3. 生成哈希值

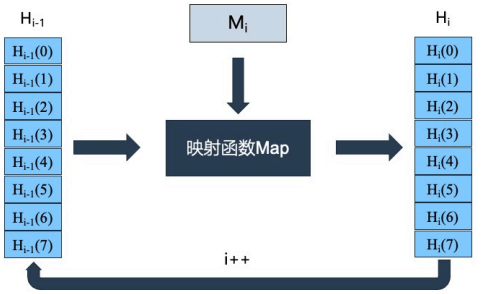
假设消息M可以被分解为n个块，于是整个算法需要做的就是完成n次迭代，n次迭代的结果就是最终的哈希值，即256bit的数字摘要



SHA256算法

- 一个256-bit的摘要的初始值H_0，经过第一个数据块进行运算，得到H_1，即完成了第一次迭代，H_1经过第二个数据块得到H_2，依次处理，最后得到Hn，Hn即为最终的256-bit消息摘要
- 将每次迭代进行的映射用 $Map(H_{i-1}) = H_i$ 表示，于是迭代可以更形象的展示为：

$$Map(H_{i-1}) = H_i$$

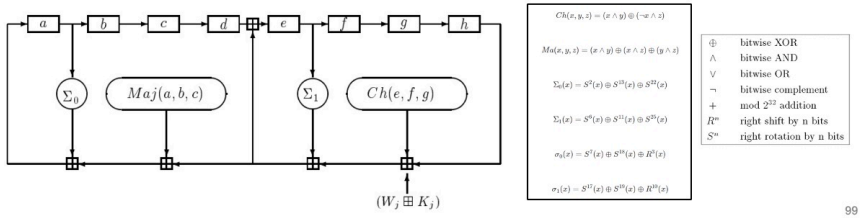


SHA256中的映射函数

Step1：构造64个32bit字（word），将每一块分解为16个32-bit的big-endian的字，记为w[0], …, w[15]，前16个字直接由消息的第i个块分解得到，其余的字由如下迭代公式得到：

$$W_t = \sigma_1(W_{t-2}) + W_{t-7} + \sigma_0(W_{t-15}) + W_{t-16}$$

Step2：进行64次循环



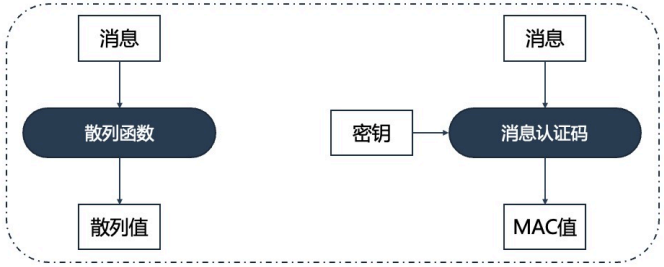
$\oplus$	bitwise XOR
$\wedge$	bitwise AND
$\vee$	bitwise OR
$\neg$	bitwise complement
$+$	mod 2^{32} addition
R^n	right shift by n bits
S^n	right rotation by n bits

比特币地址的生成

- 比特币地址的生成：
  1. 随机选取32字节的数作为私钥
  2. 椭圆曲线加密算法得到非压缩公钥
  3. 依次计算SHA-256、RIPEMD-160值
  4. 上一结果前加地址版本号（0x00）
  5. 计算两次SHA-256
  6. 取前4个字节加到第4步结果后面
  7. 进行base58编码
  8. 获得比特币地址

消息认证码

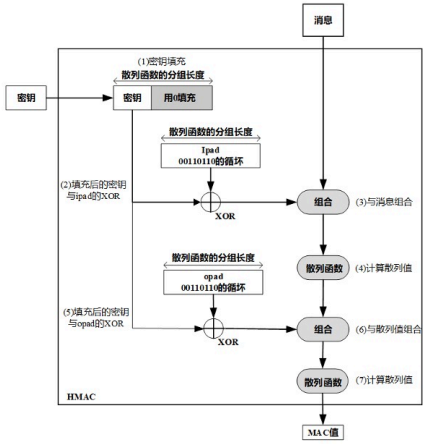
消息认证码（Message Authentication Code）的输入包括任意长度的消息和一个发送者与接受者之间共享的密钥，它可以输出固定长度的数据，这个数据称为**MAC值**



散列函数与消息认证码的比较

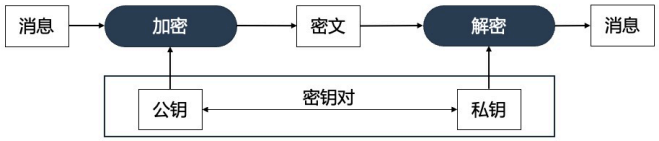
HMAC

- HMAC是一种使用散列函数来构造消息认证码的方法
- 该方法所使用的散列函数不仅限于一种，任何高强度的散列函数都可以被用在HMAC。
- 使用SHA-1，SHA-256，所构造的HMAC分别称为HMAC-SHA1，HMAC-SHA256

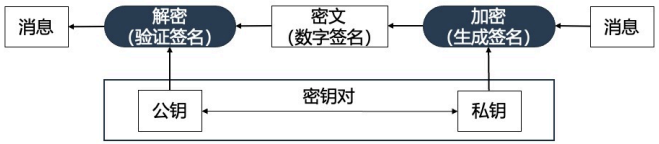


公钥加密与数字签名

(1) 公钥密码



(2) 数字签名



数字签名的方法

- 直接对消息签名的方法

A用自身私钥对消息进行签名

↓

A将消息和签名发送给B

↓

B用A的公钥对收到的签名进行解密

↓

B将签名解密后得到的消息与A直接发送的消息进行对比，若二者一致则验证成功

- 对消息的散列值签名的方法

A用单向散列函数计算消息散列值

↓

A用自己的私钥对散列值进行加密

↓

A将消息和签名发送给B

↓

B用A的公钥对收到的签名进行解密

↓

B将签名解密后得到的散列值与A直接发送的消息的散列值进行对比，若二者一致则验证成功

RSA数字签名方案

数字签名方案包括3个过程，即系统的初始化过程、签名产生过程和签名验证过程

系统的初始化过程

选择两个保密的大素数p和q，计算$n=p\times q$，l=lcm(p-1 , q-1)，选择整数e，满足1<e<l，且gcd(e, l)=1；计算de=1mod l；以{e, n}为公钥，{d,n}为私钥

签名产生过程

设消息为M，对其签名为 $S\equiv M^d mod\ n$，并将（M,S）发送给签名验证者

签名验证过程

接收方在收到消息M和签名S后，验证$M\equiv S^e mod\ n$是否成立。若成立，则发送方的签名有效；若不成立，则签名无效

数字签名的分类

- **盲签名**

  签名者不知道代签名文件内容时使用的数字签名

- **门限签名**

  如果一个群体中有n个人，那么至少需要p个人签名才视为有效签名(n>p)

- **群签名**

  一个群体由多个成员组成，某个成员可以代表整个群体来进行数字签名，而且该成员作为签名者可以被验证（群管理员可追溯签名者，可撤销）

- **环签名**

  类似于群签名，但是无法追溯签名者

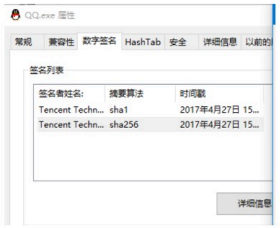
数字签名的应用

1、网站认证



2、代码签名

如果Windows上的可执行程序程序来源于正规公司，通常它会有代码签名，用于确保其来源可靠且未被篡改



3、比特币

比特币是一种完全匿名的数字货币，它的身份认证是基于ECDSA

比特币的账户地址就是对公钥计算摘要得到的，并用私钥确认账户拥有者

第5节 密码分析技术

- 唯密文攻击
- 已知明文攻击
- 选择明文攻击
- 选择密文攻击
- 选择密钥攻击

密码分析技术

- **无条件安全**
  - 明密文统计独立
  - 可以证明：满足统计学独立的加密方式，密钥空间≥明文空间，所以？……
- **实际安全性**
  - 根据破译密码系统所需的计算量来评价其安全性，分为计算安全性和可证明安全性。
  - **计算上安全**：破译一个系统在原理上可行，但已知的算法和现有的计算工具不可能完成所有要求的计算量成为计算上安全。
  - **可证明安全**：证明破译某个体制的困难性等价于（不易于）解决某个数学难题，就称之为可证明安全性。

密码分析技术

◆在未知密钥的前提下，从密文恢复出明文、或者推导出密钥，对密码进行分析的尝试

◆攻击方法分类(根据已知信息量的多少)：

- 唯密文攻击(Ciphertext only)
- 已知明文攻击(Known Plaintext)
- 选择明文攻击(Chosen Plaintext)
- 选择密文攻击(Chosen Ciphertext)

密码分析技术

◆唯密文攻击(Ciphertext only)COA
- 分析者有一些消息的密文，都是用同一算法加密的
- 分析者的目标是恢复尽量多的明文或者推算出密钥

◆已知明文攻击(Known Plaintext)KPA
- 密码分析者不仅可以得到一些消息的密文，而且也知道这些消息的明文
- 分析者的任务是得到加密的密钥或者得到一个算法，该算法可以解密用同样的密钥加密的消息

◆选择明文攻击(Chosen Plaintext)CPA
- 分析者不仅知道一些消息的明密文，而且可以选择被加密的明文，比已知明文攻击更加有效
- 分析者的任务是得到加密的密钥或者得到一个算法，该算法可以解密用同样的密钥加密的消息

◆选择密文攻击(Chosen Ciphertext)CCA
- 密码分析者能选择不同的被加密的密文，并可以得到对应的解密的明文，任务是推出密钥
- 主要针对公钥算法

密码分析技术

- Success in dealing with unknown ciphers is measured by these four things in the order named, perseverance, careful methods of analysis, intuition, luck. The ability at least to read the language of the original text is very desirable but not essential.

  ——Colonel Parker Hitt "The Manual for the Solution of Military Ciphers"

- 毅力、审慎的分析方法、直觉、运气

密码分析技术

- 密码算法的相对安全性
  - 破解算法的代价大于加密数据本身的价值
  - 破解算法的时间超过了信息的生命期

Average Time Required for Exhaustive Key Search

Key Size (bits)	Number of Alternative Keys	Time required at 10^6 Decryption/μs
32	$2^{32} = 4.3 \times 10^9$	4.3 milliseconds
56	$2^{56} = 7.2 \times 10^{16}$	20 hours
128	$2^{128} = 3.4 \times 10^{38}$	5.4×10^{18} years
168	$2^{168} = 3.7 \times 10^{50}$	5.9×10^{30} years

113

常见的攻击方式

古典密码：
　　单字母代换 唯密文攻击
　　多字母代换 已知明文攻击
分析分组密码：
　　差分分析（找到明文的变化对密文的影响）选择明文攻击；
　　线性分析（找到算法的近似线性表达式从而破解算法） 已知明文攻击；
　　利用中间相遇方法进行攻击
　　强力攻击：穷举；字典
分析序列密码：
分析哈希算法：
　　抗原像攻击（单向性）：给定杂凑值h，找到M使得h=H(M)是困难的。
　　抗第二原像攻击（弱抗碰撞性）：给定消息M1，找到另外一个消息M2使得H(M1)=H(M2)是困难的。
　　抗强碰撞攻击：找到两个消息M1,M2使得H(M1)=H(M2)是困难的
　　生日攻击：利用哈希值的取值空间不够大而制造碰撞的攻击方法。没有利用Hash函数的结构和任何代数弱性质。
分析公钥密码：
密码协议分析：
　　攻击检验方法：采用现有的一些对协议的有效攻击方法逐个对协议进行攻击，检验其是否具有抵抗这些攻击的能力。
　　形式化分析方法：采用形式语言对安全协议进行安全性分析。重点放在协议涉及的通信各方的信任以及由这些信任的进一步推演所得到的通信结果上。

114

主要内容

围绕数据加密的主题，介绍保障网络空间安全的核心技术——密码学，纵观密码学的发展历程，阐述密码学的理论基础，总结密码学的应用现状



115